GUÍA PRÁCTICA · NEIRO AGENCY

Security Audit: que Claude revise la seguridad de tus desarrollos



Una página que funciona no es lo mismo que una página segura. Security Audit es la skill que le enseña a Claude a revisar el código como lo haría un auditor: buscando fallas reales, con evidencia, y diciéndote cuál arreglar primero.

Marcos Vargas IA · Sistemas · Automatización

LO QUE APRENDERÁS

01 Qué es Security Audit y qué revisa

02 Los dos modos: consulta puntual o auditoría completa

03 Cómo leer los resultados sin asustarte ni confiarte

04 Qué hace para no dañar nada mientras revisa

05 Cómo pedirla bien

06 El error más común al interpretar una auditoría

07 Cómo la uso yo

SECCIÓN 01
QUÉ ES

Una revisión defensiva que parte del código fuente.

Es una skill de revisión de seguridad para repositorios de código, APIs, servicios, herramientas de línea de comandos, librerías y procesos en segundo plano. Su enfoque es **defensivo** y parte del código fuente: busca vulnerabilidades que crucen un límite de confianza real y entrega, por cada hallazgo, la evidencia en el código, cómo reproducirlo de forma segura, la prioridad y el arreglo más pequeño que lo resuelve.

Incluye guías por dominio: autenticación y protocolos web, código del lado del cliente, nube y despliegue, aislamiento de datos, cadena de suministro, aplicaciones con IA y modelos de lenguaje, y más. No modifica tu código: describe qué cambiar y cómo probarlo.

SECCIÓN 02
DOS MODOS

Consulta puntual o auditoría completa.

MODO GUÍA	MODO AUDITORÍA COMPLETA
Para preguntas de seguridad, revisiones enfocadas o investigar un hallazgo concreto. Usa solo las partes que aplican y no crea archivos.	Solo si lo pedís explícitamente (“auditá este repositorio”, “revisión completa”). Corre seis fases y genera reportes.

Las seis fases: reconocimiento del código y sus límites de confianza, búsqueda por olas con control de cobertura, validación de cada candidato, salida estructurada, verificación independiente y reporte final. Tiene perfiles `quick`, `standard` y `deep`, y se puede acotar a ciertas carpetas o a los cambios entre dos versiones.

SECCIÓN 03
LEER RESULTADOS

Solo lo confirmado recibe severidad.

- **Confirmado:** con camino demostrado en el código y resultado concreto. Recibe severidad: crítica, alta, media, baja o informativa.
- **Necesita validación:** hay una sospecha fundada, pero falta un dato que no está en el repositorio (por ejemplo, la configuración del servidor o del proxy). No lleva severidad.
- **Rechazado:** se investigó y no cruza ningún límite de seguridad.

La regla de fondo: sin un actor, un recurso afectado y un resultado concreto, no es un hallazgo. Eso evita las listas infladas de “buenas prácticas faltantes” que parecen alarmantes pero no son explotables.

SECCIÓN 04
SEGURIDAD DEL PROCESO

Revisa sin romper nada.

- Leer el código es de solo lectura. Si necesita ejecutar algo, lo hace solo en un entorno aislado, sin red, con datos de mentira y límites de tiempo y memoria.
- No prueba tus servidores en producción ni usa datos de usuarios reales. Lo que solo se puede comprobar en el entorno desplegado queda marcado como pendiente de validar.
- En auditoría completa, los reportes se guardan fuera del repositorio por defecto (`~/security-audit-skill/<repo>/run-N`), para que no terminen subidos a Git por accidente.

SECCIÓN 05
CÓMO PEDIRLA

Decí el alcance, el modo y qué tiene tu proyecto.

REVISIÓN ENFOCADA

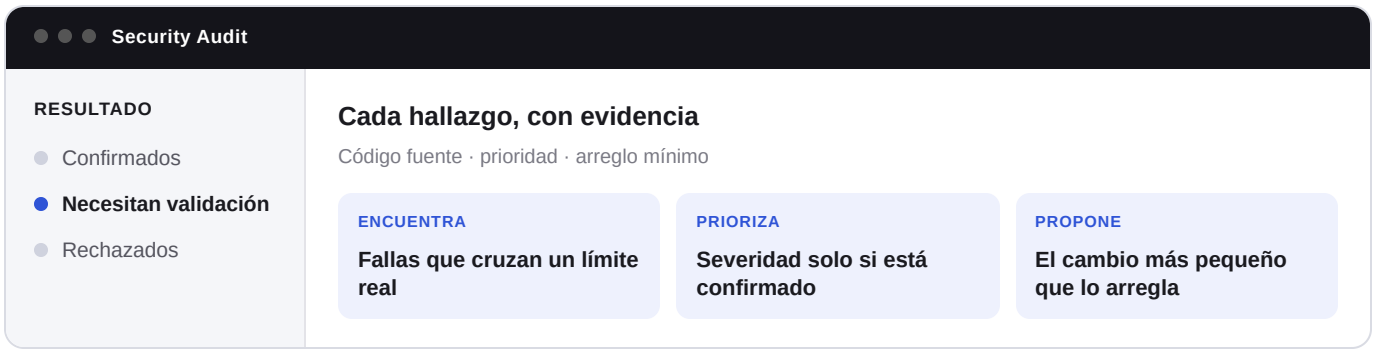
“Revisá la seguridad de esta página antes de publicarla: autenticación, formularios, manejo de datos y claves expuestas.”

AUDITORÍA COMPLETA

“Hacé una auditoría completa de este repositorio con perfil quick y dame el reporte.”

Después de corregir, volvé a pedirla solo sobre lo que cambió. Es más barato y verifica que el arreglo funcionó.

SI TU PROYECTO TIENE…	LA SKILL SE FIJA EN…
Login, sesiones o API	Autenticación: contraseñas, recuperación de cuenta, tokens, claves de API.
Mucho JavaScript en el navegador	Contenido ajeno que se muestra en la página sin filtrar.
Datos de varios clientes	Aislamiento: que un cliente no pueda ver ni cambiar datos de otro.
Nube, contenedores o CI	Permisos, configuración por ambiente y cadena de dependencias.
Chatbots o agentes con IA	Que el modelo no pueda acceder a datos o acciones que el usuario no tiene.



EL ERROR MÁS COMÚN

Leer “cero hallazgos” como “mi página es segura”. La skill misma lo advierte: ninguna pasada es completa, y lo que depende del servidor, la nube o el proveedor puede quedar fuera de lo que se ve en el código. Si tu sitio maneja pagos o datos sensibles, esta revisión es un primer filtro muy bueno, pero no reemplaza a un profesional.

CÓMO LO USO YO

La uso cuando hago desarrollos o páginas web: antes de publicar le pido a Claude que revise toda la seguridad del proyecto y me señale cualquier problema, para corregirlo antes de que lo vea un cliente o un usuario.

SIGUIENTE PASO

Elegí un proyecto que tengás a medio terminar, pedí una revisión enfocada, corregí lo confirmado y volvé a pasarla sobre los cambios. Hacelo antes de cada publicación, no después de un problema.

Importante: los comandos, números de instalaciones, estrellas y versiones que aparecen acá se revisaron en octubre de 2026, pueden variar según la región y cambian rápido. Confirmá siempre en el sitio oficial antes de instalar o decidir.

Contenido basado en la experiencia práctica de Neiro Agency. La descripción de la skill se basa en su documentación; los resultados dependen del proyecto revisado.